

CÓMO CREAR MÉTRICAS DE CIBERSEGURIDAD E INFORMES EJECUTIVOS

Manual práctico y conciso de implementación

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

Propósito

Use este manual para trabajo legal, autorizado y defensivo. Adapte los controles al riesgo, las obligaciones legales, la accesibilidad y los recursos disponibles.

Estrategia de medición

- Comience con decisiones empresariales, preguntas de riesgo y resultados.
- Defina audiencia, propósito, propietario, fórmula, fuente, frecuencia, meta, umbral y limitaciones.
- Use medidas adelantadas, históricas, cobertura, calidad, riesgo y resiliencia.

Calidad y gobierno de datos

- Asigne propietarios y valide integridad, consistencia, oportunidad y linaje.
- Automatice cuando sea práctico con revisión humana.
- No compare cuando cambien definiciones sin explicarlo.

Métricas operativas

- Mida cobertura de controles, vulnerabilidades, identidad, detecciones, incidentes, recuperación, proveedores, nube, capacitación y excepciones.
- Use tasas y denominadores, no solo conteos.
- Segmente por criticidad, exposición, servicio y tendencia.

Métricas de riesgo y resultados

- Relacione condiciones técnicas con impacto empresarial probable.
- Muestre riesgo residual, concentración, eficacia y recuperación demostrada.
- Evite precisión falsa.

Informes ejecutivos

- Comience con decisiones necesarias, cambios de exposición, excepciones y recursos.
- Use tendencias, umbrales y lenguaje claro.
- Separe hechos, estimaciones, supuestos y aceptación.

Metas e incentivos

- Defina metas según apetito de riesgo y capacidad.
- Evite metas que incentiven ocultar incidentes o cerrar hallazgos antes de tiempo.
- Revise el comportamiento que produce cada métrica.

Hoja de ruta y tablero

- Días 1-30: audiencias, preguntas, propietarios y diez medidas. Días 31-60: fuentes, umbrales e informes. Días 61-90: automatización, revisión y retiro de métricas sin valor.

- Tablero recomendado: riesgos principales, tendencia, cobertura crítica, incidentes, acciones vencidas, pruebas de recuperación, concentración de proveedores y decisiones.

Lista de implementación

- ☐ Responsable asignado
- ☐ Alcance aprobado
- ☐ Inventario completo
- ☐ Riesgos priorizados
- ☐ Políticas documentadas
- ☐ Controles implementados
- ☐ Evidencia conservada
- ☐ Excepciones con vencimiento
- ☐ Pruebas completadas
- ☐ Revisión directiva registrada

Referencias oficiales

- NIST SP 800-55 Volume 2: <https://csrc.nist.gov/pubs/sp/800/55/v2/final>
- NIST Cybersecurity Measurement: <https://www.nist.gov/cybersecurity-measurement>
- NIST CSF 2.0: <https://www.nist.gov/cyberframework>

Licencia

Copyright © 2026 Alberto (Al) Leiva. Licencia CC BY-NC-SA 4.0.